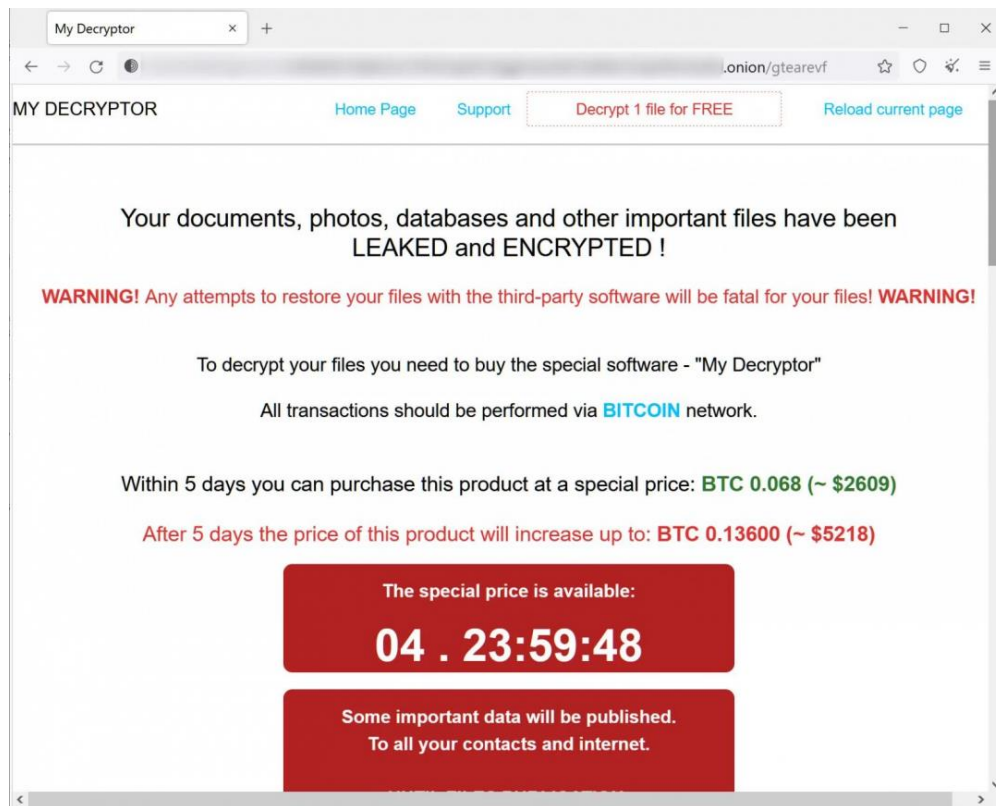


國都汽車

2022 年資安教育教材~~

1. PC 用戶別上當！駭客勒索病毒假冒「Windows Update」更新檔入侵電腦

資料來源：2022/05/02 自由時報



惡名昭彰的 Magniber 勒索軟體近日再度現身流竄，且這次瞄準的是一般消費者用戶，而非企業用戶，且發動攻擊的範圍遍及全球各地。

據外媒 [BleepingComputer](#) 報導，近日已接獲數起遭勒索病毒 Magniber 惡意感染的案例。此次 Magniber 勒索軟體是利

用偽裝成由 Windows 10 作業系統提供的「Windows Update」更新檔名義，並透過如 Warez 這類專門提供盜版軟體下載的非法網站進行惡意散播。

一旦在來路不明的網站下載了這些夾帶有惡意文件的假冒版「Windows Update」檔案後，電腦裝置就會遭勒索病毒的入侵感染，並針對各式檔案文件類型進行加密，且還會刪除系統的影子副本，使受害者無法嘗試從系統還原檔案，並強迫受害者需支付約 2600 美元（約台幣 7.6 萬元）的贖金、或用 0.068 比特幣，才能贖回經加密的文件。甚至還威脅限制要在五天內完成付款，否則贖金就會加倍。

為保護電腦裝置避免遭惡意勒索病毒的威脅感染，建議 PC 用戶需安裝任何 windows 更新檔時，務必從微軟官方的更新目錄網站上，查找所需的檔案並於官網下載。

從新聞中，我們可以學到：

不要到盜版軟體的非法網站去下載安裝任何非法軟體，裡面往往暗藏許多病毒、惡意程式，輕則帳號密碼被盜錄，嚴重如感染勒索病毒，資料、錢財兩失。如 PC 遇到勒索病毒，應先立即關閉電腦，拔除網路，並送到電腦公司請專業人員救援資料，及早關機被加密的檔案越少，資料才得以救回來。

2. 資安研究人員警告應小心夾帶惡意 Word 檔案之 PDF 檔

資料來源：2022/06/27 資安人



資安研究人員近期發現新型態攻擊手法，該攻擊於 PDF 內放入惡意 Word 檔案，並附於電子郵件中傳送。現今大多數攻擊手法為惡意電子郵件附帶 Word 或 Excel 檔案，並於檔案內嵌入惡意之巨集，誘騙使用者點選執行，但隨著大眾越來越了解 Office 附加檔案之威脅性，駭客開始找尋其他方法躲避檢測，PDF 檔案即為其中一種。

HP Wolf Security 公布之報告中，駭客嘗試寄送內含 PDF 檔案之釣魚信件，檔案命名為匯款發票，打開 PDF 後，Adobe Reader 會提示使用者打開 Word 檔，因此行為很罕見，易令使用者感到困惑。提示框內說明「此檔案已被驗證」，此訊息易使受駭者相信 Adobe 已驗證該檔為合法檔案，並可安全地打開。使用者打開後將啟用巨集功能，並自遠端下載 RTF(Rich Text Format)檔案，內含特製物件連結與嵌入(Object Linking and Embedding, OLE)物件。研究人員分析 OLE 物件後發現，其含有企圖開採 CVE-2017-11882 漏洞且加密之 Shellcode。

微軟於 2017 年修補之 CVE-2017-11882 位於 Equation Editor 工具中，為 Office 預設工具，可於文件中插入與編輯方程式，在微軟修補該漏洞前，其存在已長達 17 年。透過利用 CVE-2017-11882，RTF 檔案中之 shellcode 可下載並執行 Snake Keylogger，其為模組化資訊竊取工具，具有躲避檢測、資料收集及資料洩露等多種功能。



從新聞中，我們可以學到：

即便看似平常的郵件夾檔，那怕是

PDF、JPG、MP4 等檔案格式都有可能被

駭客包裝成糖果的外衣，唯有提高警覺、辨識可疑的郵件，不輕易開啟檔案或是連結，才能避免落入駭客的陷阱。

3.駭客滲透 Ikea 內部及供應商，寄送網釣郵件!

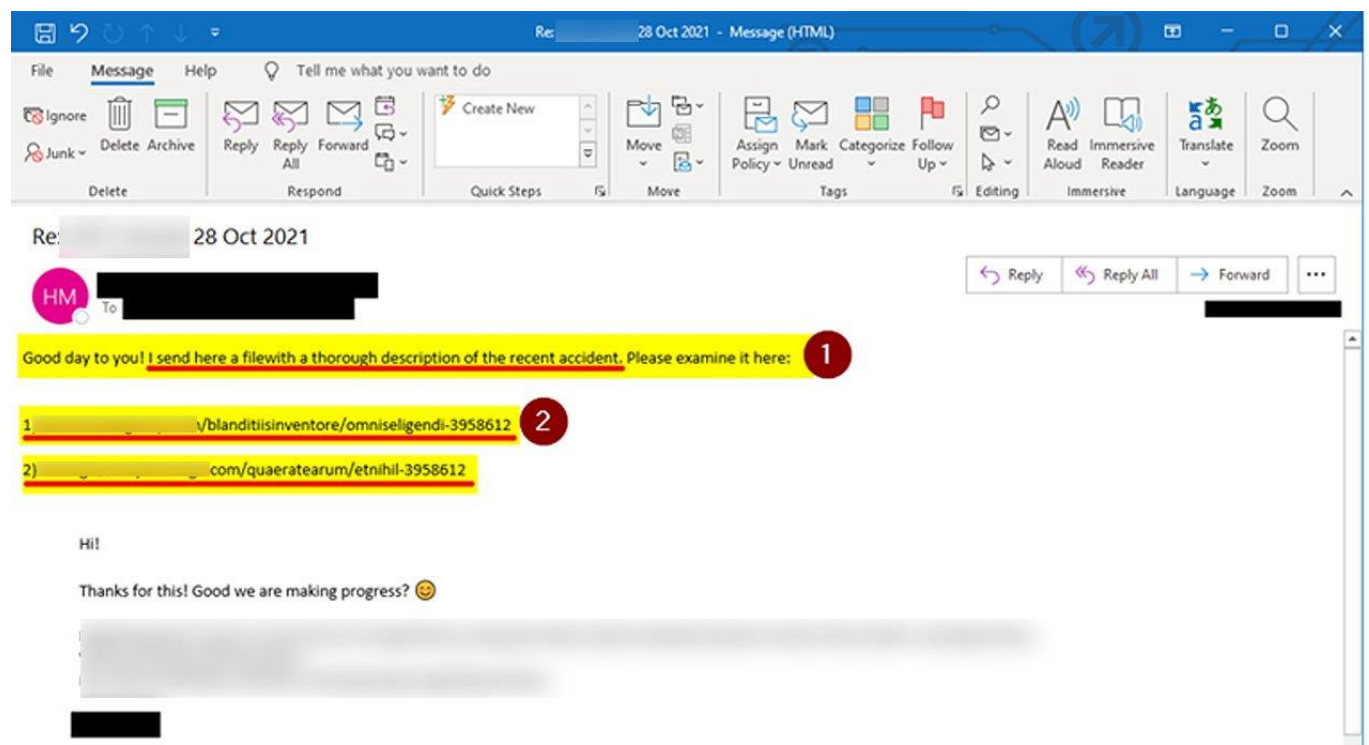
資料來源：2021/11/29 iThome

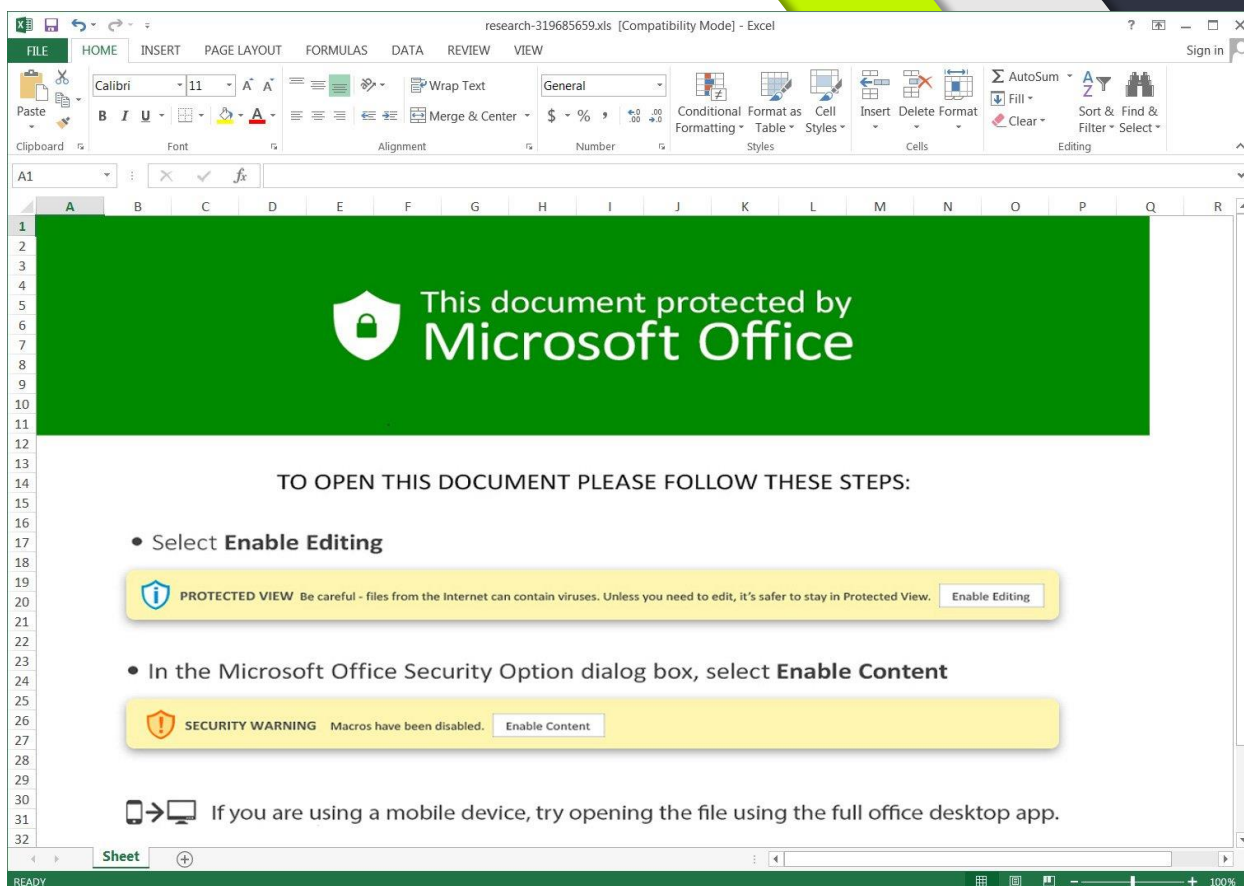


總部設於瑞典的居家用品製造商 Ikea 近日傳出遭到駭客鎖定，駭客藉由滲透 Ikea、供應鏈及合作夥伴的電子郵件，在郵件中的回覆鏈上嵌入惡意連結，類似趨勢科技日前提出警告的攻擊模式。

《BleepingComputer》取得了 Ikea 發給員工的內部郵件，指出駭客已鎖定該公司內部的郵件信箱發動網釣攻擊，這些郵件的寄件者可能是 Ikea 員工、Ikea 的供應商或者是 Ikea 的合作夥伴，而且出現在員工的郵件往來中，以回覆的方式夾帶惡意連結，因而經常能躲過郵件過濾機制，同時取得員工的信任。

當 Ikea 員工點選了該連結之後，就會被引導至下載一個惡意 Excel 文件的壓縮檔，進而於受害者系統上安裝木馬程式，可用來展開進一步的危害。





目前並不確定駭客滲透 Ikea 的方式是否與趨勢科技所描述的手法一致，根據趨勢的說法，駭客是透過藏匿在微軟 Exchange Server 上的 ProxyLogon 與 ProxyShell 漏洞，入侵組織的郵件系統，再透過內部的伺服器與已經受害的電子郵件帳號來回覆郵件，以提高惡意郵件的可信度，達到攻擊的目的。



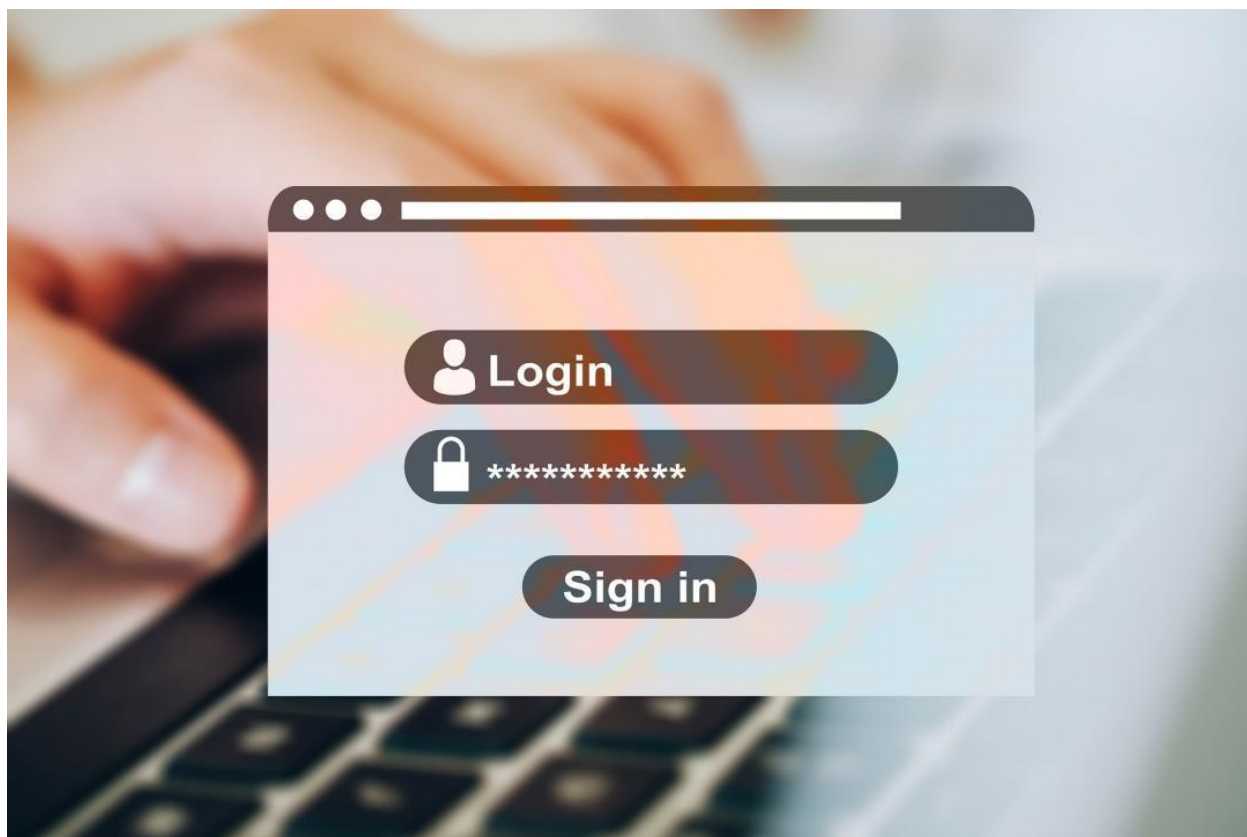
從新聞中，我們可以學到：

1. 即便是來自於集團、關係企業、供應鏈的郵件，仍有可能遭到駭客滲透，傳送惡意郵件，所以啟用郵件多重驗證有其重要性，避免駭客竊取郵件帳密，偽造合法郵件散佈惡意程式、釣魚郵件。

目前公司使用 O365 信箱皆有啟用多重驗證功能，登入信箱都要透過手機 APP 或簡訊驗證，為的就是確保郵件使用的安全。

4. 密碼長度與強度怎樣設最不易被駭客破解？一張圖秒懂！

資料來源：2022/03/21 自由時報



為防止帳號遭駭入侵的資安風險，目前多數的網站都會自動檢查用戶的密碼強度，如要求數字與符號混合、或數字符號搭配英文大小寫等組合，甚至有的會強烈要求密碼組合的字元至少需要超過八個

以上。到底密碼要怎麼設立才安全呢？

密碼長度越長，代表越不容易被駭客破解嗎？

網路安全廠商 Hive Systems 針對密碼的字元數與駭客破解需花費時間，發佈最新研究報告，據數據統計的圖表顯示，僅使用阿拉伯數字組合的密碼，即使密碼長度超過 8 個以上，仍是最容易被瞬間破解的。此外，需注意的是，就算密碼採用混合數字、英文大小寫與符號的組合，只要長度低於 8 個字元，駭客同樣也是花不到一分鐘就能輕易破解。彙整最易被駭客在一分鐘內破解的密碼類型，如下所列：



2022					
Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols
4	Instantly	Instantly	Instantly	Instantly	Instantly
5	Instantly	Instantly	Instantly	Instantly	Instantly
6	Instantly	Instantly	Instantly	Instantly	Instantly
7	Instantly	Instantly	2 secs	7 secs	31 secs
8	Instantly	Instantly	2 mins	7 mins	39 mins
9	Instantly	10 secs	1 hour	7 hours	2 days
10	Instantly	4 mins	3 days	3 weeks	5 months
11	Instantly	2 hours	5 months	3 years	34 years
12	2 secs	2 days	24 years	200 years	3k years
13	19 secs	2 months	1k years	12k years	202k years
14	3 mins	4 years	64k years	750k years	16m years
15	32 mins	100 years	3m years	46m years	1bn years
16	5 hours	3k years	173m years	3bn years	92bn years
17	2 days	69k years	9bn years	179bn years	7tn years
18	3 weeks	2m years	467bn years	11tn years	438tn years

 [Learn about our methodology at hivesystems.io/password](https://hivesystems.io/password)

一、駭客可在低於 2 秒內瞬間破解的密碼

4 個到 11 個數字組合。

4 個到 8 個的英文字母小寫組合。

4 個到 6 個的英文字母大小寫組合。

4 個到 6 個的數字與英文字母大小寫組合。

4 個到 6 個的數字混合英文字母大小寫與符號的組合。

二、駭客可在低於一分鐘內破解的密碼

12 個數字組合 2 秒內破解。

13 個數字組合 19 秒內破解。

9 個英文小寫字母組合 10 秒內破解。

7 個英文字母大小寫組合 2 秒內破解。

7 個數字與英文字母大小寫組合 7 秒內破解。

7 個數字混合英文字母大小寫與符號的組合 31 秒內破解。

若改換一個角度來看，怎樣的密碼組合，會讓駭客得花上至少 3 年的時間才會破解？從 Hive Systems 釋出研究報告的圖表可以看出，基本上需要符合兩個條件，就是

密碼字元長度至少要在 10 個以上，
且密碼需採數字混合英文大小寫字母。

另，若密碼組合還有參雜符號，相對地駭客要破解的難度與時間也越高。例如：10 個數字與英文字母大小寫組合，需花 3 年破解；11 個數字混合英文字母大小寫與符號的組合，則需花長達 34 年破解。



從新聞中，我們可以學到：

公司系統不論開機、和泰資訊系統、O365 信箱都有規定密碼原則，包含長度、複雜度、效期、重複次數以及錯誤鎖定，為的就是避免遭駭客用暴力方式破解，同仁在設定密碼時也應避免使用生日、員工編號、車號等容易遭人猜出的數字來當作密碼。

5.報復性出遊小心三大網路陷阱！少用公共 WiFi

「易洩個資」 資料來源：2022/07/27 自由時報



雖然台灣每日確診人數仍高達 2 萬多人，不過比起高峰期，似乎有緩慢下降的趨勢，加上政府祭旅遊補助以及全球解封，讓悶了好久的台灣民眾蠢蠢欲動，不僅國內旅遊需求大增，也愈來愈多人選擇

踏出國門，根據桃園機場統計，7月暑假第一天的出境人數爆衝3倍，顯見旅遊市場出現復甦景象。

趨勢科技特別提醒三大事項，在享受假期之餘，也別忘留心網路陷阱，免了壞了出遊的好興致。

風險一、網路訂房、線上購票暗藏個資外洩陷阱 詐騙電話接不停

網路訂房、購票網站非常方便，也有不少人喜歡搶購優惠及促銷，但卻可能存在詐騙風險。提醒民眾如果接獲自稱是旅遊業者或訂房網站的電話，請先向業者求證，千萬不要輕易透露個資或卡號，並應定期檢查信用卡刷卡紀錄及更改密碼。



風險二、假冒政府發布補助簡訊 誤點

連結錢財遭盜領

根據趨勢科技最新調查數據顯示，自今年 3 月政府頒發防疫補助紓困方案以來，已有近千筆防疫補助相關詐騙事件發生，有民眾就收到假冒政府發布防疫補貼的簡訊通知，簡訊內附帶假的網址吸引民眾點擊，目的就是要騙取個資、信用卡資訊和網銀帳號密碼等銀行帳戶登入資訊，甚至篡改驗證資料進而轉出大筆資金。提醒民眾一律使用政府官方機構提供的連結網址，直接在官網申請相關補助，切勿點取不明簡訊與連結。

風險三、公共場所 WiFi 資安問題頻傳 個人私密資訊都被看光光

公共場所的資安問題層出不窮，國內外飯店、機場或是火車站等場所皆有提供免費 WiFi，雖然省錢便利，也要小心伴隨的風險，特別是透過未經加密的公共 WiFi 傳送資料，將使駭客有機會隨時連上開放網路，掌握使用者上網行為，盜取信用卡、帳密等個資。建議民眾出門在外如必要使用公共 WiFi，可先關閉自動檔案分享 / 同步功能、使用 VPN 應用程式來保護 WiFi 連線，或安裝防毒軟體工具來封鎖惡意網址，簡單的小動作可防止隱私被偷窺、個資遭外洩。

從新聞中，我們可以學到：

貪圖方便之餘往往會落入資安的陷阱，有些人行動上網沒有申請吃到飽，所以會到處搜尋免費的公用網路，或有商家提供的上網服務，這些往往是透過未加密的 WIFI 傳送資料，容易遭駭客盜取各種資料，所以最好避免使用，如非使用不可也避免傳輸機敏資料，或是申請 VPN 加密服務，以確保資料不外洩。

=====教材 End =====

閱讀完以上內容後

請填寫線上測驗卷

才算完成本次個資教育喔！

國都汽車 2022 年資安教育線上測驗

<https://forms.office.com/r/RtuH3MwrqR>

